

Compliance Framework

Mapping between this platform’s technical controls and the requirements of SOC 2, ISO 27001, and regulatory standards.

SOC 2 Trust Service Criteria

SOC 2 evaluates five trust service categories. This table maps each criterion to the platform’s existing controls.

Security (Common Criteria)

Criterion	Description	Platform control	Status
CC1.1	Control environment	SECURITY.md, CONTRIBUTING.md, CI/CD pipeline	Done
CC2.1	Information and communication	Audit trail middleware, structured logging	Done
CC3.1	Risk assessment	Threat model in SECURITY.md	Done
CC4.1	Monitoring	Prometheus metrics, Grafana dashboards, health endpoint	Done
CC5.1	Control activities	ACL deny-by-default, endorsement policies, mTLS	Done
CC6.1	Logical access controls	X.509 MSP, JWT authentication, org-based authorization	Done
CC6.2	System account management	Per-org identity, key rotation support	Partial
CC6.3	Encryption in transit	TLS 1.3 (rustls), mTLS for P2P	Done
CC6.6	Encryption key management	Signing key zeroization, env-based secrets	Partial

Criterion	Description	Platform control	Status
CC6.7	Threat detection	Rate limiting, audit logging, signature verification	Done
CC7.1	System monitoring	Prometheus counters, health checks with dependency verification	Done
CC7.2	Incident response	Vulnerability disclosure policy in SECURITY.md	Done
CC8.1	Change management	Git workflow, CI/CD, PR reviews	Done

Availability

Criterion	Description	Platform control	Status
A1.1	Processing capacity	Configurable P2P buffer sizes, rate limiting	Done
A1.2	Recovery objectives	Graceful shutdown, persistent Raft log, RocksDB durability	Done
A1.3	Backup and recovery	Snapshot API (per-channel), pull state sync	Done

Processing Integrity

Criterion	Description	Platform control	Status
PI1.1	Completeness and accuracy	MVCC validation, endorsement policy enforcement	Done
PI1.2	Transaction processing	Execute-order-validate pipeline, Raft consensus	Done
PI1.3	Error handling	Structured API errors, poison recovery on mutexes	Done

Confidentiality

Criterion	Description	Platform control	Status
C1.1	Confidential information identification	Channels, private data collections	Done
C1.2	Confidential information disposal	Key zeroization, collection TTL purge	Partial

Privacy

Criterion	Description	Platform control	Status
P1.1	Privacy notice	Not applicable (infrastructure, not end-user facing)	N/A

ISO 27001 Annex A Controls

ISO 27001:2022 Annex A defines 93 controls in 4 themes. The following maps relevant controls to the platform.

A.5 — Organizational controls

Control	Description	Platform evidence	Status
A.5.1	Information security policies	SECURITY.md, CLAUDE.md conventions	Partial
A.5.23	Information security for cloud services	Docker deployment with TLS, health checks	Done
A.5.33	Protection of records	Append-only audit store, immutable block ledger	Done

A.6 — People controls

Control	Description	Platform evidence	Status
A.6.1	Screening	Not applicable (open source project)	N/A

A.7 — Physical controls

Control	Description	Platform evidence	Status
A.7.1	Physical security perimeters	Not applicable (software-only)	N/A

A.8 — Technological controls

Control	Description	Platform evidence	Status
A.8.1	User endpoint devices	N/A (server-side)	N/A
A.8.2	Privileged access rights	ACL deny-by-default, admin role inference from X.509 CN	Done
A.8.3	Information access restriction	Channel isolation, private data collection membership	Done
A.8.5	Secure authentication	mTLS, JWT, X.509 MSP	Done
A.8.7	Protection against malware	Wasm sandbox (Wasmtime), no arbitrary code execution	Done
A.8.9	Configuration management	Environment variables, Docker Compose, documented defaults	Done
A.8.10	Information deletion	Key zeroization, private data TTL	Partial
A.8.12	Data leakage prevention	Channel isolation, private data dissemination to members only	Done
A.8.15	Logging	Audit trail middleware, Prometheus metrics	Done
A.8.16	Monitoring activities	Grafana dashboards, health endpoint with dependency checks	Done
A.8.20	Networks security		Done

Control	Description	Platform evidence	Status
A.8.24	Use of cryptography	mTLS for all P2P, gossip signature verification Ed25519 + ML-DSA-65, SHA-256, HMAC-SHA256, TLS 1.3	Done
A.8.25	Secure development lifecycle	CI/CD (lint, test, security scan), code review, TDD	Done
A.8.26	Application security requirements	Input validation middleware, rate limiting	Done
A.8.28	Secure coding	Rust memory safety, no unsafe in signing module, clippy -D warnings	Done
A.8.31	Separation of environments	Docker Compose per-node isolation, RUST_BC_ENV for prod/dev	Done

Regulatory alignment

Chile — CMF (Comision para el Mercado Financiero)

Requirement	Platform control
NCG 311 (Cybersecurity)	Threat model, audit trail, access control, encryption in transit
Ley 19.628 (Data Protection)	Private data collections, channel isolation, key zeroization
Digital identity frameworks	X.509 MSP, DID support, ML-DSA-65 post-quantum signatures

European Union

Requirement	Platform control
eIDAS 2.0	ML-DSA-65 (FIPS 204) for quantum-safe digital signatures
GDPR Art. 32	Encryption in transit (TLS), access control (ACL), audit logging

Requirement	Platform control
Cyber Resilience Act	Vulnerability disclosure policy, secure development lifecycle
DORA (financial sector)	Monitoring, incident response, operational resilience

United States

Requirement	Platform control
FISMA	FIPS 140-3 prep (KAT self-tests, module boundary), FIPS 204 signatures
EO 14028	SBOM capability (Cargo.lock), secure supply chain (cargo-audit)
CNSS Policy 15	ML-DSA-65 post-quantum cryptography

What exists vs what needs organizational process

Category	Technical controls (in code)	Organizational process (needs humans)
Access control	ACL, mTLS, JWT, channel membership	Access review schedule, role definitions
Cryptography	FIPS 204, KAT, key zeroization	Key management policy, rotation schedule
Monitoring	Prometheus, Grafana, audit trail	Alerting rules, on-call rotation
Incident response	Vulnerability disclosure policy	Response team, communication plan
Change management	CI/CD, git workflow	Change advisory board, approval process
Risk management	Threat model in SECURITY.md	Risk register, periodic reassessment
Business continuity	Graceful shutdown, persistent storage	DR plan, RTO/RPO targets, drill schedule

The platform provides the technical foundation. Certification requires wrapping these controls in organizational policies, evidence collection, and auditor engagement.